
Hillside Primary School Visit Report

Audit Date: 11/02/20

Report: Year 2 visit 3

DPE: Stuart Lee

School member: Lynsey Boulton

1. Visit details

The school has a proactive approach to GDPR in school which continues to be led in part by Lynsey and supported by the school governor (Matthew) and headteacher (Simon). The school uses the DPE website and checklists to monitor progress with staff already completing the e-learning training. The school had also built in internal walks to improve practice. The school is used by Brownies (extended services).

The focus of the visit was to review previous reports and compliance actions (checklists). Lynsey had recently attended the latest DPE workshop. The governorhub GDPR Guidance for Governors and Clerk's checklist documentation was downloaded for the school to complete at a later date.

Record of Processing Tool (RoP) main list of processes was perused. SL to send Lynsey (attached with report) the list in order to confirm the schools master list of processes. This will support the next visit where the focus will be on the RoP tool completion.

Discussed in detail risks to data working out of school and adapting DPE documentation for the school. The school can use DPEs model policy (adapting as appropriate) or add additional guidance to the staff handbook. Simon confirmed most was covered in current staff documentation but will review to ensure everything is covered.

2. Audit walk findings

Lynsey reminds staff regularly of best practice both verbally and via email which further embeds best practice for data handling and storage in school.

There was good practice observed and good staff awareness with staff spoken to. 1 x list with DOB and full name observed on display (Y7 class) and the in the SRB room 1 x Rainbow folder that contained sensitive medical information with out of data information, which was easily assessible. As per previous reports and visits, not all classrooms have lockable storage and the school operates a folder system for each classroom, with each folder containing sensitive data (Rainbow folders). Discussed with Lynsey and Simon using GDPR as an opportunity to move to electronic systems, minimising data in Rainbow folders and having main information on secure systems/MIS system. The school will continue to review current practice.

Good practice was observed in pre-school with a layered approach being practiced; sensitive data in a cabinet; cabinet and office locked at night and minimal data on display.

3. Compliance actions that should now be completed

Initial documents:

- Privacy Notice
- GDPR Policy
- Data Breach Procedure.
- SAR procedure

- **Photo and Video consent**

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. If using GDPRiS this should also be kept updated. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

3.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- IRMS toolkit: https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016_IRMS_Toolkit_for_Schools_v5_Master.pdf
- DfE toolkit https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf (Annex 5,1)

Lynsey has completed an asset register which SL checked during the visit and had a query regarding providing full details to anyone who request this (publication scheme): Should the full list of assets for the school be an option and hard copy available? SL didn't think so and to have a top-level register that is available with the detailed register available for view only, unless officially being requested (i.e. audits). SL to raise with JE. School will update the publication scheme to reflect this.

School downloaded FOI policy during the visit and will also update website to include FOI with the FOI and Scheme being added to a separate section.

3.2. Staff training

GDPR training should be completed and documented. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

3.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

3.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

4. Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

5. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

6. Next steps

Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

6.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

7. Norfolk County Council Summer GDPR audits

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>